



Governance, Risk & Compliance – "Threats to Backlog"

RAM Tier 24GB · Full

DEPARTMENT	RAMTIER	MACHINES	DIFFICULTY
Governance, Risk & Compliance	24GB · Full	one machine (Docker + Threat Dragon + tracker) ·	Advanced → Expert

// MISSION

Turn a threat model into a real remediation plan. Go beyond identifying threats – deploy a vulnerable app, build its STRIDE threat model, validate the threats, score every risk using a formal framework (DREAD or OWASP Risk Rating), and then convert the entire threat register into a prioritised remediation backlog with sprint assignments and a visual roadmap. This is how security teams translate risk into engineering work.

// LABS TO DOWNLOAD

Docker + threat-modeling + project-tracking tools (all free).

- Docker (docker.com) – deploy the target app
- OWASP Juice Shop: `docker run -p 3000:3000 bkimminich/juice-shop`
- OWASP Threat Dragon (desktop or web: threatdragon.com)
- A backlog tracker – use a **spreadsheet** (Excel/LibreOffice/Google Sheets) or a free Kanban tool:
- Focalboard: github.com/mattermost/focalboard (free, open-source Kanban/project board)
- Taiga: github.com/taigaio/taiga-docker (free Agile PM, Docker deploy)
- A risk-scoring framework: **DREAD** (Damage, Reproducibility, Exploitability, Affected Users, Discoverability) or **OWASP Risk Rating Methodology**

// SETUP

1. Deploy Juice Shop: `docker run -p 3000:3000 bkimminich/juice-shop`.
2. Open Threat Dragon for the threat model.
3. Set up your backlog tracker (spreadsheet or Focalboard/Taiga).

// PROCEDURE

1. **Threat model the app** (as in 16GB): build DFDs in Threat Dragon, apply STRIDE, validate ≥ 6 threats against the live app.
2. **Score every threat** using DREAD or OWASP Risk Rating:
 - **DREAD**: rate each factor 1–10 (Damage, Reproducibility, Exploitability, Affected users, Discoverability), average = risk score.
 - Classify: Critical (8–10), High (6–7.9), Medium (4–5.9), Low (1–3.9).
3. **Build a risk-scored threat register** (≥ 12 threats):

THREAT	STRIDE	DREADSCORE	RISKLEVEL	VALIDATED?
SQL injection in search	I/E	8.2	Critical	Yes
Weak default admin creds	S	7.6	High	Yes
...	...	...	...	...

4. **Convert threats to remediation backlog items.** Each threat becomes a task:
 - Title, priority, description, acceptance criteria, effort estimate, ATT&CK reference.
5. **Assign to sprints by priority:**



Z E R O D A Y R E A P E R S × T H E X S S R A T

CYBERSECURITY INTERNSHIP · WEEK 04



T A S K I D / / Z D R - W 4 - G R C - 2 4 G B

D E P T 0 4 · G R C

- Sprint 1 (Critical): SQL injection, broken auth, IDOR.
- Sprint 2 (High): XSS, rate limiting, verbose errors.
- Sprint 3 (Medium): CSP headers, password policy, audit logs.

6. Create a visual remediation roadmap – Kanban board screenshot, Gantt chart, or structured table showing the timeline.

Deliverable: Complete threat-model-to-remediation pipeline – STRIDE threat model → risk-scored threat register (DREAD/OWASP) → prioritised remediation backlog → sprint assignments → visual roadmap.

// REQUIRED OUTPUT · PDF REPORT

Submit a professional PDF report. Structure it like a real GRC deliverable:

- Introduction & objectives
- Target application & deployment
- Threat modeling methodology (STRIDE + DREAD/OWASP)
- Tools used
- Data Flow Diagrams with trust boundaries
- STRIDE threat analysis with validation results
- Risk-scored threat register
- Remediation backlog (linked to threats)
- Sprint assignments & visual roadmap
- Screenshots with the clock visible
- Recommendations
- Conclusion & lessons learned

⚠ **SCREENSHOT RULE** - proof of original work. Every screenshot you paste into your report must clearly show your own PC's date & time (system clock / taskbar). This proves the screenshots are yours and were not taken from the internet. Reports with screenshots that hide or crop the clock will not be accepted.

Same skill & difficulty for every tier – RAM only decides how deep the local build goes. 100% free. Submission & deadline: zerodayreapers.me/portal

R A M T I E R L A D D E R

☐ 8GB

☐ 16GB

☒ 24GB